Regulamin Konkursu Bug Bounty COI, edycja 11/2026

§1 Przedmiot regulaminu

1. Niniejszy regulamin określa zasady konkursu pn. “Konkurs Bug Bounty COI”, zwany dalej również „Konkursem”, w tym czas trwania konkursu, zakres systemów i typów podatności, zasady przyznawania nagród i wykluczenia.
2. Integralną część niniejszego Regulaminu stanowi Regulamin Platformy Bug Bounty (serwisu hack.cert.pl), dostępny pod adresem https://hack.cert.pl/regulamin, zwany dalej: „Regulaminem Platformy”.
3. Regulamin Konkursu jest dostępny na Platformie, w zakładce Konkursu. Jego akceptacja jest warunkiem niezbędnym do wzięcia udziału w Konkursie oraz poddania Zgłoszenia ocenie. Przekazanie Zgłoszenia jest równoznaczne z akceptacją Regulaminu Konkursu oraz Regulaminu Platformy.

§2 Organizator konkursu

1. Organizatorem Konkursu jest Naukowa i Akademicka Sieć Komputerowa – Państwowy Instytut Badawczy z siedzibą w Warszawie, ul. Kolska 12, 01-045 Warszawa, wpisany do Krajowego Rejestru Sądowego pod numerem 0000012938 przez Sąd Rejonowy dla m.st. Warszawy, będący jednocześnie Operatorem Platformy.
2. Partnerem Konkursu jest Centralny Ośrodek Informatyki, Al. Jerozolimskie 132-136, 02-305 Warszawa, NIP: 7252036863, REGON: 100999489.

§3 Czas trwania konkursu

1. Okres przyjmowania Zgłoszeń w Konkursie trwa od dnia 03.11.2026 r. do dnia 30.11.2026 r.

§4 Uczestnicy konkursu

1. Uczestnikiem Konkursu może być każdy Użytkownik Platformy, o którym mowa w §4 Regulaminu platformy Bug Bounty (serwisu hack.cert.pl).
2. Użytkownik Platformy może wziąć udział w Konkursie poprzez wysłanie Zgłoszenia wyłącznie za pośrednictwem swojego konta na Platformie.
3. W Konkursie może wziąć udział Uczestnik, który:
    a. ukończył 18 rok życia i posiada status polskiego rezydenta podatkowego;
    b. akceptuje niniejszy Regulamin;
    c. w przypadku osób nieposiadających pełnej zdolności do czynności prawnych, przedstawi zgodę przedstawiciela ustawowego.

4. Uczestnik zapewnia sobie we własnym zakresie wszelkie narzędzia i środki, w tym środki techniczne niezbędne do udziału w Konkursie przyjmuje do wiadomości, że udział w Konkursie odbywa się wyłącznie na jego koszt i ryzyko.
5. Wyłącznie spełnienie wszystkich warunków określonych w niniejszym Regulaminie i Regulaminie Platformy stanowić będzie dokonanie poprawnego Zgłoszenia. Zgłoszenia naruszające postanowienia ww. Regulaminów nie będą brane pod uwagę przy przyznawaniu nagród.
6. W konkursie nie mogą brać udziału pracownicy i współpracownicy Partnera oraz członkowie ich najbliższej rodziny. Przez członków najbliższej rodziny rozumie się wstępnych, zstępnych i powinowatych w linii prostej oraz rodzeństwo, wstępnych, zstępnych i powinowatych do drugiego stopnia linii bocznej (w tym małżonków, małżonków rodzeństwa, rodziców małżonków) i osoby pozostające w stosunku przysposobienia. Przez współpracowników Partnera rozumie się osoby fizyczne, które w okresie trwania Konkursu wykonują na rzecz Partnera zadania lub świadczą usługi na podstawie zawartych z nim umów cywilnoprawnych, w szczególności umowy zlecenia, umowy o dzieło lub umowy o świadczenie usług, w tym w ramach prowadzonej działalności gospodarczej.
7. Uczestnictwo w Konkursie jest całkowicie dobrowolne oraz bezpłatne. Uczestnikowi nie przysługuje prawo żądania zwrotu nakładów finansowych poniesionych w związku z dokonaniem Zgłoszenia i uczestnictwem w Konkursie.

§5 Zakres systemów objętych konkursem

1. W zakres Konkursu wchodzą następujące domeny: **www.gov.pl**
2. Zakresem Konkursu objęte są wyłącznie systemy dostępne bezpośrednio z sieci internet, bez konieczności użycia VPN lub innych mechanizmów dostępu zdalnego opartego o poświadczenia lub konta domenowe Partnera.

§6 Zasady przeprowadzania testów bezpieczeństwa

W Konkursie obowiązują dodatkowe wymagania dotyczące przeprowadzania testów bezpieczeństwa:

1. Testy mogą być prowadzone bez uwierzytelnienia, a w przypadku uwierzytelnienia - wyłącznie z użyciem kont własnych (poza domenowymi) lub kont testowych. Nie wolno korzystać z kont innych użytkowników.
2. Dopuszczalne jest użycie automatycznych narzędzi z maksymalną szybkością skanowania na poziomie 5 req/s.

3. Naruszenie zasad, o których mowa w niniejszym paragrafie, może skutkować odrzuceniem Zgłoszenia, o czym Uczestnik zostanie poinformowany za pomocą Platformy.

§7 Zasady przyznawania i wypłaty nagród

1. Organizator dokonuje oceny Zgłoszeń i ogłasza wyniki Konkursu za pośrednictwem Platformy.
2. Oceny Zgłoszeń konkursowych dokona komisja konkursowa złożona z przedstawicieli Organizatora (Analityków).
3. Decyzja komisji jest ostateczna i nie przysługuje od niej odwołanie.
4. Zwycięzcy konkursu, zwani dalej „Zwycięzcami", zostaną wyłonieni przez komisję spośród Uczestników.
5. Zgłoszenia będą rozpatrywane sukcesywnie, według kolejności ich wpływu albo w turach określonych przez Organizatora. Organizator może dokonywać wyboru Zwycięzców i informować ich o przyznaniu Nagrody w trakcie trwania Konkursu, bez konieczności oczekiwania na upływ terminu przyjmowania Zgłoszeń.
6. Wysokość nagrody w Konkursie jest uzależniona od krytyczności (CVSS 4.0) zgłoszonej podatności, zgodnie z poniższą tabelą:

Niska (0.1 - 3.9)	**Średnia (4.0 - 6.9)**	**Wysoka (7.0 - 8.9)**	**Krytyczna (9.0 - 10.0)**
600 zł	4000 zł	9000 zł	20 000 zł

7. Pula nagród w Konkursie wynosi 100 000zł. Organizator może zdecydować o zwiększeniu puli nagród w trakcie trwania konkursu.
8. W przypadku, gdy więcej niż jeden Uczestnik zgłosi tę samą podatność, o przyznaniu Nagrody danemu Uczestnikowi decyduje data i godzina dokonania prawidłowego Zgłoszenia takiej podatności, odnotowana przez Organizatora, jako pierwsze Zgłoszenie.
9. Nagrody są wypłacane w walucie polskiej na polski rachunek bankowy wskazany przez Uczestnika, którego jest on posiadaczem lub współposiadaczem.
10. Do Nagrody zostaje dodana dodatkowa nagroda pieniężna stanowiąca równowartość zryczałtowanego podatku od Nagrody. Rzeczona dodatkowa nagroda pieniężna nie jest wypłacona Uczestnikowi, lecz zostaje pobrana jako podatek zryczałtowany od wartości przyznanej Nagrody, o którym mowa w ustawie z dnia 26 lipca 1991 r. o podatku dochodowym od osób fizycznych (tekst jednolity: Dz. U. z 2000 r., Nr 14, poz. 176 z późn. zm) na co Uczestnik wyraża zgodę. Za pobranie i odprowadzenie należnego podatku odpowiedzialny jest wyłącznie Operator.

11. Warunkami wydania Nagrody są:
    a. przestrzeganie niniejszego Regulaminu oraz Regulaminu Konkursu;
    b. przekazanie danych i oświadczeń niezbędnych do wypłaty Nagrody.
12. Nagrody są wypłacane nie później niż w terminie 60 dni kalendarzowych od dnia ogłoszenia wyników.
13. Z zastrzeżeniem § 7 pkt 5 Regulaminu, wyłonienie Zwycięzców Konkursu następować będzie każdorazowo nie później niż w terminie do 30 dni kalendarzowych po zakończeniu danej edycji Konkursu.
14. Organizator poinformuje Zwycięzców pocztą elektroniczną (e-mailem) lub za pośrednictwem Platformy o fakcie przyznania nagrody. Organizator zastrzega sobie również prawo do opublikowania informacji o zwycięzcach i nagrodzonych inicjatywach na swoich stronach internetowych oraz kanałach w mediach społecznościowych. Informacja o wynikach Konkursu podawana przez Organizatora do wiadomości publicznej może zostać ograniczona do podania liczby otrzymanych Zgłoszeń oraz liczby Zwycięzców w danym Konkursie.
15. Zwycięzcy niezwłocznie, w terminie 7 dni kalendarzowych, za pośrednictwem Platformy potwierdzą Organizatorowi fakt przyjęcia informacji o wygranej i gotowość do odebrania Nagrody.
16. Zwycięzca nie może zrzec się praw do nagrody na rzecz innego podmiotu.
17. Organizator nie ponosi odpowiedzialności za brak możliwości przyjęcia nagrody lub nagród z przyczyn od niego niezależnych. Nieodebranie nagrody w terminie oznacza utratę praw do niej.

§8 Zakres typów podatności objętych konkursem

1. Konkurs obejmuje następujące typy podatności:

Typy podatności objęte Konkursem	1) Zdalne wykonanie kodu a) Zdalne wykonanie kodu (RCE / Remote Code Execution) b) Eskalacja do kontroli nad systemem lub usługą 2) Pełne przejęcie konta (podatności, które bezpośrednio pozwalają atakującemu przejąć konto użytkownika) m.in.: a) Reset hasła bez dostępu do skrzynki pocztowej lub numeru telefonu ofiary. b) Przejęcie sesji lub tokenów uwierzytelniających c) Logowanie bez znajomości hasła d) Fałszowanie tożsamości użytkownika 3) Dostęp do danych wrażliwych

	a) Wyciek danych osobowych umożliwiający identyfikację osób b) Dostęp do prywatnych treści lub wiadomości innych użytkowników c) Masowy odczyt wrażliwych danych użytkowników lub danych systemowych 4) SQL injection 5) Server-Side Request Forgery (SSRF) a) Odczyt zasobów dostępnych tylko z sieci wewnętrznej za pośrednictwem SSRF b) Dostęp do usług prywatnych (Dostęp do niepublicznych usług lub portów poprzez SSRF) c) Pełny SSRF umożliwiający RCE 6) Server-Side Template Injection (SSTI) a) Wykonanie kodu po stronie serwera poprzez podatność w silniku szablonowym 7) Podatności związane z przesyłaniem plików (File Upload) a) Przesyłanie pliku prowadzące do RCE b) Ominięcie filtrów typu MIME lub rozszerzeń prowadzący do podatności c) Ominięcie mechanizmów walidacji przesyłania plików prowadzące do istotnego wpływu na bezpieczeństwo takiego jak: możliwość wykonania kodu, uzyskanie nieautoryzowanego dostępu do zasobów. 8) Cross-Site Scripting (XSS) - poza określonymi wyłączeniami 9) Autoryzacja i dostęp a) IDOR / Broken Access Control b) Odczyt, modyfikacja lub usuwanie cudzych danych c) Omijanie autoryzacji w warstwie aplikacji (UI/Web) umożliwiające wykonywanie akcji lub dostęp do zasobów bez wymaganych uprawnień. 10) Eskalacja uprawnień a) Pionowa b) Pozioma 11) Problemy z sesją i uwierzytelnianiem (nieprowadzące bezpośrednio do pełnego przejęcia konta) a) Nadużycie sesji poprzez ponowne użycie tokena po wylogowaniu, brak rotacji ID sesji, brak wygasania sesji, które same w sobie nie umożliwiają przejęcia konta innych użytkowników. b) Brak wymaganego uwierzytelnienia do funkcji lub endpointów, które same w sobie nie pozwalają na zmianę stanu kont innych użytkowników ani odczytu

	prywatnych danych (dostęp do listy publicznych zasobów lub dokumentacji niepoprawnie chronionej). c) Pozostawione domyślne dane uwierzytelniające, które same w sobie nie umożliwiają przejęcia danych użytkowników (konto developerskie z ograniczonymi uprawnieniami np do panelu monitoringu). *Problemy w tej kategorii nie prowadzą do przejęcia konta i będą traktowane jako informacyjne lub nagradzane niską kwotą według uznania zespołu weryfikującego zgłoszenia. 12) Podatności w API a) Omijanie autoryzacji na poziomie API (brak walidacji tokenów, brak sprawdzania uprawnień w endpointach). b) Dostęp do endpointów prywatnych (Dostęp do wewnętrznych, ukrytych lub nieudokumentowanych endpointów API prowadzący do wycieku danych lub akcji). 13) Mass Assignment a) Nadpisanie pól, których użytkownik nie powinien zmieniać (np. role=admin) 14) Błędna konfiguracja CORS a) Odczyt wrażliwych danych (Tylko jeśli błędna konfiguracja umożliwia odczyt danych przez nieautoryzowane domeny). b) Wykonanie akcji w kontekście zalogowanego użytkownika wyłącznie z powodu błędnej konfiguracji CORS. 15) Path Traversal / LFI / RFI a) Odczyt, zapis, modyfikacja lub usuwanie lokalnych plików na serwerze (np. LFI/L, path traversal), jeśli pozwalają uzyskać dostęp do danych wrażliwych lub wpływać na konfigurację systemu) 16) CSRF z realnym wpływem na bezpieczeństwo a) zmiana danych lub stanu konta użytkownika (usunięcie konta, zmiana maila, dodanie użytkownika). 17) Open Redirect wyłącznie, jeśli spełniony jest co najmniej jeden z poniższych warunków: • Redirect URI w przepływie OAuth/OIDC umożliwia przekierowanie na zewnętrzną domenę z przechwyceniem kodu uwierzytelnienia lub tokenu dostępu

	• Open Redirect na domenie organizacji jest wykorzystywany jako ogniwo w udokumentowanym łańcuchu ataku (np. phishing z zaufaną domeną, bypass CSP) • Open Redirect osiągnięty przez HTML Injection z możliwością przekierowania ofiary Subdomain takeover z działającym PoC przejęcia kontroli. 18) Web Cache Poisoning i inne ataki prowadzące do nieautoryzowanej modyfikacji treści serwowanych innym użytkownikom (w tym treści pochodzących z cache), poza treściami wprowadzanymi przez użytkownika. 19) HTTP Request Smuggling (CL.TE, TE.CL, TE.TE) prowadzący do: • przechwycenia żądań innych użytkowników (request hijacking), • obejścia mechanizmów bezpieczeństwa (np. WAF, autoryzacji), • uzyskania dostępu do wewnętrznych endpointów dostępnych tylko z zaufanych źródeł, • ataków typu cross-site request smuggling (np. w połączeniu z XSS lub CSRF). 20) XML External Entity Injection (XXE) prowadzące do: • odczytu lokalnych plików systemu operacyjnego (np. /etc/passwd, kluczy prywatnych), • wykorzystania jako wektor SSRF do dostępu do sieci wewnętrznej, • zdalnego wykonania kodu (RCE), np. przy użyciu mechanizmów takich jak expect lub innych technik eskalacji.

2. Z Konkursu wyłączone zostały następujące typy podatności:

Typy podatności wyłączone z Konkursu	1) Podatności wymagające konta w zasobach wewnętrznych podmiotu (np. w AD) lub specjalnych uprawnień posiadanych wyłącznie przez pracownika testowanego podmiotu bądź podmiotu z nim współpracującego. 2) Wyciek informacji, który nie prowadzi do ujawnienia wrażliwych ani istotnych danych, ani nie umożliwia atakującemu przeprowadzenia dalszych nadużyć. Są one klasyfikowane jako niskie ryzyko, jeśli same w sobie nie umożliwiają przejęcia konta, zwiększenia uprawnień, wykonania akcji w imieniu użytkownika ani dostępu do

	danych wrażliwych. Dotyczy to w szczególności wycieków, takich jak: a) Stack trace, wersje oprogramowania, IP, ścieżki, listingi katalogów). b) User enumeration (np. sprawdzenie czy e-mail istnieje) c) Wycieki metadanych lub danych publicznych d) Autocomplete w formularzach e) Publiczne endpointy debugowe bez możliwości eskalacji f) Brak walidacji po stronie klienta. 3) Problemy konfiguracyjne, które nie tworzą wektorów ataku a) Brak lub niepełne nagłówki bezpieczeństwa (X-Frame-Options, CSP, X-XSS-Protection, Referrer-Policy itp.) b) HSTS c) brak captchy d) brak flag security w nagłówkach i ciasteczkach e) Mixed content warnings f) Brak weryfikacji SPF/DKIM/DMARC (jeśli nie umożliwia spoofingu) g) Wygasłe certyfikaty SSL, brak zgodności nazwy certyfikatu z domeną, algorytmy szyfrowania uznawane za słabe, problemy z TLS bez realnego scenariusza ataku z zewnątrz. h) Otwarty port bez znaczenia bezpieczeństwa i) Nieaktualne oprogramowanie/biblioteki bez wpływu j) Znane CVE bez działającego PoC. 4) Wymagające nieuzasadnionych lub nierealnych założeń a) Ataki wymagające MITM, proxy, przejęcia sieci użytkownika b) Ataki wymagające fizycznego dostępu do urządzenia ofiary c) Wykorzystanie funkcji deweloperskich przeglądarki (DevTools) d) Ataki działające jedynie na archaicznych/przestarzałych przeglądarkach. 5) Ataki frontendowe, które da się wywołać tylko po stronie użytkownika, nie pozwalają uruchomić złośliwego kodu u innych osób oraz nie wpływają na bezpieczeństwo danych - na integralność, poufność ani dostępność. a) Self-XSS b) Tabnabbing. (wymaga pełnej interakcji użytkownika, nie powoduje realnego wpływu bezpieczeństwa i jest uznawane za problem przeglądarki/UX, a nie podatność aplikacji)

	c) Content injection bez wykonania kodu d) Clickjacking bez krytycznej akcji e) XSS lub Open Redirect w nagłówku Host bez możliwości wykorzystania f) Błędnie zaimplementowana polityka CORS nie prowadząca do kradzieży danych (np. brak Access-Control-Allow-Origin: * bez możliwości kradzieży danych). g) czysty HTML injection bez możliwości JS 6) CSRF (wykluczone są zgłoszenia dotyczące problemów które nie mają realnego wpływu na integralność, poufność ani dostępność danych). a) CSRF w akcjach niezmieniających stanu użytkownika (logout, profil bez zmian, ekrany read-only) b) CSRF niewymagające faktycznego uwierzytelnienia lub niewpływające na dane. 7) Blind SSRF, gdzie jedynym dowodem jest odpowiedź DNS (brak możliwości odczytu danych lub eskalacji). 8) Open Redirect wymagający pełnej interakcji użytkownika bez realnego scenariusza phishingowego lub przechwycenia tokenu. 9) Problemy z kontami i sesjami niskiego wpływu a) Informacje o wymaganiach haseł (złożoność, długość) b) Polityki bezpieczeństwa haseł, które są zbyt liberalne, ale nie stanowią podatności 10) Ataki związane z zasobami a) Denial of Service (DoS / DDoS) – wszystkie formy ataków skutkujących zakłóceniem lub przerwaniem działania usług są zabronione. b) Testy obciążeniowe c) Brak rate limiting bez realnego scenariusza ataku (np. brak możliwości przejęcia konta) d) Możliwość wykonania ataku typu spam (wysyłanie wielu powiadomień/e-maili/SMS) 11) Podatności wymagające zewnętrznych narzędzi lub ingerencji a) CSV injection bez działającej formuły lub bez możliwości wykonania kodu b) Subdomain takeover bez działającego PoC przejęcia kontroli. 12) Klucze API i integracje zewnętrzne a) Ujawnione klucze API bez możliwości nadużyć. b) Ujawnione klucze API z restrykcjami domenowymi lub tylko do odczytu.

	c) Ujawnienie referera do zaufanych usług typu analytics/ads bez ataku. 13) Social engineering & wektory nietechniczne a) Phishing wobec pracowników. b) Social engineering wobec kontraktorów, partnerów i moderatorów. 14) Scenariusze teoretyczne lub nieudowodnione a) Podatności zgłaszane bez PoC. b) "Potencjalne" ataki bez realnej ścieżki wykonania c) Wymagające niestandardowej konfiguracji, rozszerzeń, proxy lub manipulacji przeglądarką d) Raporty na podstawie automatycznych skanerów bez ręcznego potwierdzenia. 15) Wewnętrzne błędy UX/UI a) Błędy tekstowe, literówki, grafika, layout. b) Niepoprawne komunikaty błędów c) Problemy użyteczności bez wpływu na bezpieczeństwo

§9 Postanowienia końcowe

1. Uczestnicy, którzy w rażący sposób naruszą postanowienia niniejszego Regulaminu, podlegają wykluczeniu z Konkursu.
2. Organizator zastrzega sobie prawo do zmiany zapisów Regulaminu w dowolnym momencie, w tym do zmiany terminu rozstrzygnięcia Konkursu oraz zmiany terminu przyznania Nagród.
3. Prawa i obowiązki Organizatora i Uczestników Konkursu określone są wyłącznie w niniejszym Regulaminie, Regulaminie Platformy oraz w bezwzględnie obowiązujących przepisach prawa. Wszelkie informacje o Konkursie dostępne w materiałach reklamowych i promocyjnych mają jedynie charakter informacyjny.
4. Organizator nie odpowiada za Zgłoszenia, które naruszają prawa autorskie lub inne prawa osób trzecich, jak również w wypadku, jeśli istnieje duże prawdopodobieństwo wystąpienia takich naruszeń, ani za jakiekolwiek treści naruszające powszechnie obowiązujące przepisy prawa, wolność słowa i dobre obyczaje.
5. Organizator nie ponosi odpowiedzialności za podanie przez Uczestnika niewłaściwych lub nieprawdziwych danych dotyczących adresu e-mail lub innych

danych uniemożliwiających lub opóźniających wręczenie przez Organizatora nagród w związku z realizacją Konkursu.

6. W sprawach interpretacji zapisów i wymogów regulaminowych decyzję podejmuje Organizator. O ewentualnych zmianach w Regulaminie Konkursu Organizator będzie informował na bieżąco na Platformie, w zakładce Konkursu.
7. Wszelkie spory i roszczenia związane z Konkursem rozstrzygać będzie sąd powszechny właściwy dla siedziby Organizatora.